

TP Introduire la sécurité informatique partie 2

Étude de cas 1 – Analyse XSS

Un site web permet aux utilisateurs de publier des commentaires.

Un utilisateur malveillant insère dans un commentaire du code JavaScript au lieu d'un texte classique.

1. Quel est le nom de cette attaque ?
2. Que peut-il se passer pour les autres utilisateurs qui consultent ce commentaire ?
3. Comment aurait-on pu éviter cette attaque ? (Donne deux méthodes)

Étude de cas 2 – Problème de mots de passe

Un administrateur de site utilise comme mot de passe "admin123" pour accéder au panneau d'administration.

1. Quel est le problème ici ?
2. Donne deux règles pour améliorer ce mot de passe.
3. Quelles sont les bonnes pratiques pour stocker des mots de passe dans la base de données ?

Étude de cas 3 – DDoS

Ton site web subit une attaque où il reçoit un grand nombre de requêtes simultanées provenant de plusieurs adresses IP, ce qui le rend indisponible.

1. Quel type d'attaque subis-tu ?
2. Quelle infrastructure pourrait aider à bloquer ce type d'attaque ?
3. Donne deux solutions techniques pour te protéger contre ce type d'attaque.

Étude de cas 4 – Site de e-commerce piraté via injection XSS

Un site de vente en ligne a été victime d'une attaque. Un pirate a injecté un script malveillant dans une section de commentaires. Ce script redirige les clients vers un site frauduleux en volant leurs cookies.

1. Quelle est la nature de cette attaque ?
2. Que fait exactement ce script malveillant une fois affiché ?
3. Pourquoi cette attaque est-elle dangereuse pour les utilisateurs connectés ?

4. Quelle erreur de développement a permis cette attaque ?
5. Propose deux mesures de protection côté serveur pour éviter ce genre d'attaque.

Étude de cas 5 – Serveur compromis par configuration par défaut

Un pirate a réussi à accéder à l'interface d'administration d'un serveur web en utilisant les identifiants par défaut "admin/admin".

1. Quelle faille a été exploitée ?
2. Pourquoi est-ce une erreur classique en configuration système ?
3. Que peut-on reprocher à l'administrateur système dans ce cas ?
4. Quelle règle de sécurité de base n'a pas été respectée ?
5. Donne trois bonnes pratiques à suivre lors de l'installation d'un serveur web en production.